COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.5 · Hardening Techniques

Mestre CyberSec · **Aula 2.5 — Hardening Techniques** (12:11) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Hardening = reduzir superfície de ataque ao mínimo: fechar portas desnecessárias, remover serviço/software (bloatware), trocar senha default, desabilitar conta não usada, patch, MFA, app allowlist, disable USB autorun, BIOS/UEFI password, disable USB boot.

💡 Highlights que a prova CompTIA cobra

- Surface de ataque = tudo que podes ser atacado — MINIMIZE
- CIS benchmarks = o checklist de hardening por plataforma (padrão da indústria)
- NÃO usar a conta default; desabilitar porta/serviço não usado

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'reduces the attack surface of a system' = hardening
- 'checklist of security configuration per platform' = CIS benchmark

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.5 — Hardening Techniques)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Hardening (Endurecimento) (N/A)
O processo de reduzir a superfície de ataque de um sistema aplicando configurações seguras, removendo componentes desnecessários e aplicando políticas de segurança rígidas.

⚠️ ***Armadilha CompTIA:*** *Any answer that 'reduces the attack surface of a system' or 'secures a default configuration' = hardening. Watch for this keyword on SY0-701 Objective 1.3.*

• Superfície de Ataque (N/A)
A soma de todos os pontos (portas, serviços, código, usuários, interfaces) onde um usuário não autorizado pode tentar entrar ou extrair dados de um sistema.

⚠️ ***Armadilha CompTIA:*** *If the question asks 'what is being minimized?', the answer is the attack surface. Hardening = minimizing the attack surface.*

• CIS Benchmarks (Benchmarks do Center for Internet Security)
Listas de verificação padrão da indústria, baseadas em consenso, para configuração segura de tecnologias, desenvolvidas pelo Center for Internet Security; usadas como linha base para hardening.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'industry-recognized checklist of security configuration per platform' or 'configuration baseline' = CIS Benchmarks. Don't confuse with NIST frameworks — CIS is the configuration guide.*

• Credenciais Padrão / Conta Padrão (N/A)
Nomes de usuário e senhas pré-configurados que acompanham um sistema (ex.: admin/admin, root). Devem ser alterados ou desativados durante o hardening, pois são publicamente conhecidos.

⚠️ ***Armadilha CompTIA:*** *Any question showing a known vendor default login being exploited = hardening failure. Both default credentials AND default accounts must be removed/renamed.*

• Bloatware (Software Inchado) (N/A)
Software pré-instalado desnecessário que acompanha um dispositivo, aumenta a superfície de ataque e deve ser removido durante o hardening.

⚠️ ***Armadilha CompTIA:*** *If a question asks 'what should be uninstalled to reduce the attack surface on a new laptop?' = Bloatware. Less software = smaller attack surface.*

• Lista de Aplicativos Permitidos (Whitelist) (N/A)

Controle de hardening que permite que SOMENTE aplicativos aprovados sejam executados no sistema, bloqueando todo o resto por padrão — o inverso de uma block list/blacklist.

⚠️ ***Armadilha CompTIA:*** *Allow list = deny by default (more secure). Block list = allow by default (weaker). On exams, prefer allow list for high-security environments. Distinguish from block list.*

• Patching (Aplicação de Patches) (N/A)

Processo de aplicar atualizações do fabricante para corrigir vulnerabilidades, bugs ou melhorar funcionalidades; atividade central de hardening para sanear exploits conhecidos.

⚠️ ***Armadilha CompTIA:*** *Question showing an unpatched CVE being exploited = patch management failure. Patching is mandatory hardening; pair with firmware/OS updates for full coverage.*

• Autorun USB (Desabilitar) (N/A)

Recurso do sistema que executa automaticamente software em um dispositivo USB conectado. Desabilitar o autorun é um controle de hardening para impedir a execução de código malicioso por mídia removível.

⚠️ ***Armadilha CompTIA:*** *Scenario: 'malware spreads by inserting a USB drive' = USB autorun was enabled. Also disable boot from USB in BIOS/UEFI to complete the hardening.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Criptografia de Disco Total com BitLocker e Chip TPM

🏠 **Analogia Intuitiva:** Se você esquecer o notebook da empresa no banco de trás de um táxi, um ladrão comum não precisa saber a senha do seu Windows: ele pode simplesmente desparafusar o HD do notebook, plugá-lo como um pen drive em outro computador e ler todos os seus arquivos e contratos em texto claro. A criptografia de disco total (BitLocker) transforma cada arquivo gravado no disco em um idioma indecifrável. E o chip TPM soldado na placa-mãe é o cofre que guarda a chave e só libera o acesso se tiver certeza de que ninguém alterou o hardware ou o sistema de boot da máquina.

🔍 **Causa Raiz / Por que foi criado:** O sistema operacional só protege os dados enquanto está ativo. Quando o computador está desligado, os dados estão em repouso (data at rest) e vulneráveis a roubo físico. A criptografia de volume total protege a confidencialidade mesmo se a mídia for fisicamente subtraída.

🛡️ **Visão do Auditor de GRC:** Fiscalizar a conformidade de 100% dos notebooks corporativos com políticas de criptografia total de disco via MDM/Intune; auditar o backup seguro e centralizado das chaves de recuperação (BitLocker Recovery Keys) no Microsoft Entra ID ou Active Directory.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'a corporate laptop is lost or stolen; what security technology prevents an attacker from extracting the storage drive and accessing sensitive data at rest?'. Resposta: Full Disk Encryption (FDE / BitLocker) with TPM.

📌 LAPS (Local Administrator Password Solution)

🏠 **Analogia Intuitiva:** Em um condomínio de 500 apartamentos, imagine se o síndico decidisse usar exatamente a mesma chave na porta de serviço de todos os 500 apartamentos para facilitar o trabalho dos zeladores. Se um ladrão roubar a chave de um único apartamento, ele agora tem a chave para abrir todas as 500 residências do prédio! O LAPS é como instalar uma fechadura inteligente em cada porta que gera uma chave diferente, aleatória e que muda toda semana para cada apartamento, guardando todas essas senhas em um cofre central blindado na administração.

🔍 **Causa Raiz / Por que foi criado:** Equipes de TI frequentemente configuravam a mesma senha para a conta de administrador local em milhares de computadores. Se um invasor comprometesse uma única estação de trabalho e extraísse essa credencial com ferramentas como o Mimikatz, ele usava a técnica de Pass-the-Hash para invadir lateralmente todas as outras máquinas da empresa.

🛡️ **Visão do Auditor de GRC:** Auditar a implantação e operação do Windows LAPS em todas as máquinas associadas ao domínio; verificar se as senhas de administrador local são únicas, complexas, rotacionadas periodicamente (a cada 30 dias) e com acesso restrito por RBAC no cofre central.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'tool that prevents lateral movement and Pass-the-Hash attacks by automatically randomizing and managing unique local administrator passwords across domain-joined computers'. Resposta: LAPS (Local Administrator Password Solution).

📌 Assinatura Digital de Código (Code Signing)

🏠 **Analogia Intuitiva:** É como o lacre plástico com selo holográfico na tampa de uma garrafa de xarope comprada na farmácia. Você confere se o selo traz a marca da fabricante confiável e se está intacto, sem rasgos. Se o lacre estiver violado, você não toma o remédio porque sabe que ele pode ter sido contaminado. A assinatura digital de código usa criptografia para provar quem foi a empresa que escreveu o software e que ninguém alterou uma única vírgula do programa desde a sua publicação.

🔍 **Causa Raiz / Por que foi criado:** Ataques à cadeia de suprimentos (Supply Chain Attacks) inserem códigos maliciosos dentro de instaladores e atualizações de programas legítimos. Sem assinatura digital validada pelo sistema operacional, os computadores executam softwares adulterados sem saber.

🛡️ **Visão do Auditor de GRC:** Exigir nas políticas de desenvolvimento seguro (DevSecOps) que 100% dos softwares, scripts e drivers internos sejam compulsoriamente assinados digitalmente com certificados emitidos por AC confiável, armazenando as chaves privadas em Módulos de Segurança de Hardware (HSM).

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'cryptographic method used to confirm the identity of the software publisher and ensure application code has not been altered in transit'. Resposta: Code Signing (Assinatura de Código).

📌 Lista de Permissão de Aplicativos (Application Allowlisting / AppLocker)

🏠 **Analogia Intuitiva:** É a lista VIP na entrada de uma festa super exclusiva. Em uma festa comum (modelo de denylist / antivírus tradicional), qualquer pessoa pode entrar, a menos que a foto dela esteja na lista de baderneiros banidos pelo clube. Em uma festa com lista VIP restrita (allowlisting), o segurança não quer saber quem é bandido: ninguém entra a menos que o nome esteja digitado na lista oficial de convidados pré-aprovados pela diretoria. Se um hacker criar um vírus novo que ninguém nunca viu na história, o vírus simplesmente não executa porque não está na lista VIP.

🔍 **Causa Raiz / Por que foi criado:** Ataques de dia zero e ransomwares novos não possuem assinaturas de antivírus conhecidas e passam facilmente por listas de bloqueio (denylisting). O modelo de lista de permissão inverte a postura de segurança, bloqueando tudo por padrão e permitindo apenas binários explicitamente confiáveis.

🛡️ **Visão do Auditor de GRC:** Fiscalizar a implementação de políticas de controle de aplicativos (Windows Defender Application Control - WDAC ou AppLocker) em estações de trabalho e servidores de produção; auditar se as permissões são baseadas em assinaturas de editores confiáveis em vez de caminhos de pastas graváveis.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'most effective defensive technique to prevent unauthorized software, malicious scripts, and unknown zero-day malware from executing on corporate computers'. Resposta: Application Allowlisting (AppLocker / WDAC).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Proteção criptográfica de dados em repouso em caso de perda ou furto físico de notebooks	**Criptografia de Disco Total (Full Disk Encryption / BitLocker)**
Solução que gera e rotaciona senhas aleatórias e únicas para a conta de administrador local de cada host	**LAPS (Local Administrator Password Solution)**
Técnica de invasão lateral onde o atacante reutiliza o hash de uma senha local para acessar outras máquinas	**Pass-the-Hash (Movimentação Lateral)**
Uso de certificados digitais para atestar a autenticidade do desenvolvedor e a integridade de um programa	**Assinatura de Código (Code Signing)**
Controle de segurança que proíbe a execução de qualquer software, exceto os expressamente autorizados	**Lista de Permissão de Aplicativos (Application Allowlisting)**
Chip de segurança na placa-mãe que armazena chaves criptográficas e valida a integridade do boot	**TPM (Trusted Platform Module)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa está preparando uma imagem hardening do Windows 11 para o departamento financeiro. A imagem atual inclui jogos, softwares de avaliação e utilitários de fornecedores que os funcionários do financeiro não usam. A equipe de segurança quer reduzir a superfície de ataque antes da implantação. Qual ação de hardening a equipe deve tomar?

A) Habilitar AutoRun para mídias removíveis para que os usuários instalem ferramentas necessárias.

B) Conceder direitos de administrador local aos usuários do financeiro para gerenciar o software extra.

C) Remover aplicativos e serviços pré-instalados desnecessários da imagem.

D) Desativar o firewall do Windows na imagem para evitar conflitos de aplicativos.

QUESTÃO 2 · CENÁRIO DE EXAME

Um técnico instala uma nova impressora multifuncional de rede na LAN corporativa. Durante uma revisão de segurança, o console web da impressora ainda está acessível com as credenciais administrativas padrão do fornecedor. Qual etapa de hardening é mais apropriada?

A) Mover a impressora para uma rede sem fio de convidados e manter as credenciais padrão.

B) Alterar as credenciais administrativas padrão e desativar contas de gerenciamento não utilizadas.

C) Desativar o gerenciamento HTTPS e usar Telnet para acesso administrativo.

D) Habilitar SNMPv1 com a community string public para facilitar o monitoramento.

QUESTÃO 3 · CENÁRIO DE EXAME

Um analista de segurança revisa um servidor de arquivos legado e descobre que a conta interna Guest está habilitada, a conta interna Administrator ainda usa seu nome original e uma conta de um administrador que saiu da empresa permanece ativa. Qual ação de hardening aborda melhor essas descobertas?

A) Definir todas as contas afetadas para usar senhas que nunca expiram.

B) Adicionar as contas a um grupo privilegiado de monitoramento para auditoria.

C) Habilitar acesso via área de trabalho remota para as contas para simplificar a administração.

D) Desativar ou renomear contas padrão desnecessárias e desativar contas inativas.

QUESTÃO 4 · CENÁRIO DE EXAME

Uma verificação de vulnerabilidades encontra uma CVE crítica em um servidor web público porque um patch necessário do sistema operacional nunca foi aplicado. Qual técnica de hardening aborda diretamente essa descoberta?

A) Aplicar os patches ausentes do sistema operacional e dos aplicativos.

B) Implementar uma application allow list no servidor web.

C) Desativar o AutoRun de USB nas estações de trabalho dos administradores.

D) Configurar uma senha de BIOS/UEFI no servidor.

QUESTÃO 5 · CENÁRIO DE EXAME

Um usuário baixa um executável malicioso da internet e o executa em uma estação de trabalho gerenciada, infectando o sistema. A equipe de segurança quer impedir que executáveis não aprovados sejam executados, mesmo que sejam baixados. Qual ação de hardening deve ser implementada?

A) Desativar o AutoRun de USB em todos os endpoints.

B) Exigir que os usuários executem como administradores locais.

C) Configurar uma application allow list que permita apenas executáveis aprovados.

D) Mover a pasta Downloads do usuário para uma unidade de rede mapeada.

QUESTÃO 6 · CENÁRIO DE EXAME

Um contratado conecta uma unidade USB a uma estação de trabalho corporativa. O malware na unidade é executado automaticamente porque o Windows processa um arquivo autorun.inf. Qual ação de hardening deve ser aplicada para evitar esse comportamento?

A) Habilitar BitLocker To Go para todos os dispositivos USB.

B) Configurar MFA para todos os logins de usuários.

C) Instalar uma application allow list apenas nos servidores.

D) Desativar AutoRun/AutoPlay para mídias removíveis por meio de Política de Grupo.

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa está preocupada com roubo de laptops e com atacantes que podem ter acesso físico breve. Eles querem evitar que alguém inicialize a partir de uma unidade USB externa e contorne os controles do sistema operacional. Qual ação de hardening é mais eficaz?

A) Definir uma senha de BIOS/UEFI e desativar a inicialização a partir de dispositivos externos.

B) Habilitar AutoRun para dispositivos USB e exigir senhas complexas.

C) Instalar uma application allow list no sistema operacional.

D) Aplicar os patches mais recentes do sistema operacional e habilitar MFA.

QUESTÃO 8 · CENÁRIO DE EXAME

O portal VPN da empresa autentica usuários apenas com nome de usuário e senha. Após uma campanha de credential stuffing, várias contas válidas foram acessadas. Qual ação de hardening mitiga melhor esse risco?

A) Desativar contas VPN não utilizadas e aplicar patches no appliance VPN.

B) Exigir autenticação multifator para acesso VPN.

C) Implementar uma application allow list nos clientes VPN.

D) Configurar senhas de BIOS/UEFI nos laptops remotos.

QUESTÃO 9 · CENÁRIO DE EXAME

Um servidor Linux interno executa FTP, Telnet e SMB, mas nenhum desses serviços é necessário para a função do servidor. Qual ação de hardening reduz melhor a superfície de ataque?

A) Instalar um firewall baseado em host e deixar os serviços em execução.

B) Habilitar MFA para logins locais e manter FTP/Telnet ativos.

C) Parar e desativar serviços desnecessários, depois fechar as portas associadas.

D) Mover o servidor para uma VLAN diferente sem alterar os serviços.

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização quer padronizar configurações seguras para seus servidores Windows e precisa de um conjunto reconhecido de benchmarks de hardening. Qual recurso deve ser usado como base?

A) CIS Benchmarks.

B) OWASP Top 10.

C) NIST SP 800-63.

D) PCI DSS.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Remover aplicativos e serviços pré-instalados desnecessários da imagem.
Remover bloatware e aplicativos/serviços pré-instalados desnecessários reduz a superfície de ataque, pois elimina código que pode conter vulnerabilidades ou ser explorado. Habilitar AutoRun, conceder direitos de administrador local e desativar o firewall aumentam o risco em vez de fortalecer o sistema.

Questão 2: Alternativa B — Alterar as credenciais administrativas padrão e desativar contas de gerenciamento não utilizadas.
Credenciais padrão são uma fraqueza conhecida e devem ser alteradas antes de o dispositivo entrar em produção. Desativar contas de gerenciamento não utilizadas também reduz a superfície de ataque. Manter padrões, usar Telnet ou habilitar SNMPv1 com public aumenta a exposição.

Questão 3: Alternativa D — Desativar ou renomear contas padrão desnecessárias e desativar contas inativas.
Contas padrão e inativas são pontos de entrada comuns. O servidor deve ter contas padrão desnecessárias desativadas ou renomeadas e contas inativas desativadas ou removidas. Senhas que nunca expiram, privilégios adicionados e acesso remoto aumentam o risco.

Questão 4: Alternativa A — Aplicar os patches ausentes do sistema operacional e dos aplicativos.
A aplicação de patches corrige vulnerabilidades conhecidas em sistemas operacionais e aplicativos e é uma técnica central de hardening. Allow list, desativação de AutoRun de USB e senha de BIOS/UEFI são controles úteis, mas não corrigem diretamente o patch ausente.

Questão 5: Alternativa C — Configurar uma application allow list que permita apenas executáveis aprovados.
Uma application allow list impede a execução de executáveis não autorizados ou maliciosos, mesmo que tenham sido baixados. Desativar AutoRun ajuda com mídias removíveis, mas não com downloads. Direitos de administrador local aumentam o risco; mover a pasta Downloads não impede a execução.

Questão 6: Alternativa D — Desativar AutoRun/AutoPlay para mídias removíveis por meio de Política de Grupo.
Desativar AutoRun/AutoPlay para mídias removíveis impede que arquivos autorun.inf maliciosos em unidades USB sejam executados automaticamente. BitLocker protege dados em repouso, MFA protege autenticação, e allow list apenas em servidores não impede autorun em estações de trabalho.

Questão 7: Alternativa A — Definir uma senha de BIOS/UEFI e desativar a inicialização a partir de dispositivos externos.
Uma senha de BIOS/UEFI e a desativação de opções de boot externo impedem que um atacante com acesso físico altere a ordem de boot ou inicialize outro sistema operacional a partir de mídia removível. Controles em nível de SO podem ser contornados se o atacante inicializar externamente.

Questão 8: Alternativa B — Exigir autenticação multifator para acesso VPN.
MFA adiciona um segundo fator além de uma senha comprometida, mitigando diretamente credential stuffing e reuso de senhas. As outras ações são medidas de hardening, mas não tratam da autenticação de fator único.

Questão 9: Alternativa C — Parar e desativar serviços desnecessários, depois fechar as portas associadas.
A ação de hardening mais forte é remover ou desativar serviços desnecessários e fechar as portas associadas, reduzindo a superfície de ataque. Firewall, MFA ou segmentação por VLAN podem ajudar, mas não eliminam os serviços vulneráveis.

Questão 10: Alternativa A — CIS Benchmarks.
CIS Benchmarks fornecem diretrizes de configuração segura baseadas em consenso para sistemas operacionais, servidores e aplicativos. OWASP Top 10 trata de riscos de aplicações web, NIST SP 800-63 cobre identidade digital, e PCI DSS é um padrão da indústria de cartões de pagamento.